COMPLIANCE 1 / ASSIGNMENT 04

Documentation & Reporting

A controlled compliance reporting package for DeRexi and the illustrative Aurum Capital Bank use case.

PREPARED	SOURCE REVIEW	DOCUMENT STATUS
November 5, 2026	Codex gap analysis, development commit c4641b5	Coursework report / proposed operating procedures

Purpose. Translate DeRexi's existing compliance documentation, policy-health measures, and security-test artifacts into a repeatable management-reporting and records-management program. This report distinguishes tested application capabilities from unverified metrics and proposed governance procedures.

Assurance boundary. The secured/test profile has passing C-01, C-02 and C-03 audit checks. The legacy main:app entry point remains unguarded; production authentication, live Supabase behavior, and public deployment were not verified. This document is not a statement of regulatory certification.

THE FOUR DELIVERABLES

01 Controlled documentation system, templates and distribution

02 Management compliance status report

03 Records-management and retention procedure

04 Defined KPI and monitoring/reporting framework

01 Documentation control system

DeRexi will use a controlled document register to connect regulatory requirements, approved policies, control tests, reports and remediation decisions. Git commits and dated technical evidence already support source traceability; they do not constitute formal policy approval or immutable user-activity audit logging.

CONTROLLED ARTIFACT	OWNER / REVIEWER	REQUIRED METADATA
Compliance policy and SOP	Compliance Lead / Product Owner	Document ID, version, effective date, reviewer, approval status, next review
Audit and evidence package	Security Lead / Independent Reviewer	Control ID, test date, environment, command, expected/actual, evidence path, reviewer
Management status report	Compliance Lead / Product Owner	Reporting period, as-of date, audience, findings, action owner, decision and distribution
Remediation register	Security Lead / Compliance Lead	Finding ID, severity, owner, target date, evidence, current status, closure approval

Standard document lifecycle

Draft → Review → Approve → Publish → Reassess → Supersede / retain. Drafts are identifiable as unapproved. Only a designated approver may authorize a controlled release. A version update references the superseded version and describes material changes. Approval should be evidenced by approver identity, timestamp, decision, and retained artifact.

Document naming and distribution rule

Use a stable identifier such as DRX-CMP-004, revision v0.1, and ISO dates in the register. Distribute the management report to the Product/Business Owner and Compliance Lead; distribute technical findings on a need-to-know basis to the Security Lead, relevant Policy Owners, and authorized reviewer. Recipient, date, version, delivery method, and acknowledgement remain fields to complete; no distribution is claimed.

Version control vs operational audit evidence

GitHub history supports code/document revisions, while DeRexi policy version rows support content history. Neither alone proves signed approval, employee record access, policy-status transitions or tamper-proof archival. These gaps remain in the remediation register.

02 Management compliance status report

REPORTING PERIOD • NOVEMBER 3–5, 2026

Executive status. The three audited technical controls improved from initial deficiencies to passing checks in controlled secured, offline and browser test environments. DeRexi has operational policy, feedback, incident and governance paths, but production identity provisioning and several audit-history features remain incomplete. Priorities are securing the supported entry point, validating dashboard metric definitions, and completing case-workflow regressions.

15 / 15	26 / 26	55 / 55
C-01 RBAC	C-02 Validation	C-03 Feed Integrity

RISK / CONDITION	BUSINESS IMPACT	OWNER / NEXT ACTION
Legacy compatibility API entry point remains unguarded	A public or misconfigured launch could bypass protected profile.	Technical Lead: restrict to loopback and enforce secured deployment entry point.
Production authentication and Supabase not verified	Cannot claim secure institution-ready login or live data isolation.	Technical Lead: provision controlled identity mapping, verify on approved staging.
Messages endpoint and incident guidance failures	Incomplete employee clarification and incident-assistance journey.	Application Lead: restore route, resolve four guidance failures and retest.
Dashboard metric definitions need focused tests	Misleading review and incident counts could distort governance decisions.	Compliance + Technical Leads: metric dictionary, corrections and verification.

Management decision requested: authorize a secured staging pilot and targeted dashboard/recordkeeping remediation. Formal sign-off and distribution have not occurred; record the decision, decision maker and date when approved.

03 KPI dictionary & monitoring

Metrics must retain their precise source, formula, scope, as-of time and limitations. Test pass ratios below measure technical checks in a specific environment, not enterprise regulatory compliance.

MEASURE	DEFINITION / SOURCE	STATUS & INTERPRETATION
Policy inventory	Count all policy rows, including draft and retired; backend policy_health.	Total count asserted in synthetic tests; not a count of approved policies.
Reviews due	Latest version flagged requires_review, date on/before UTC today + 30 days, approved policy only.	Code exists; cutoff/edge cases not fully validated. Includes upcoming and overdue.
Clarifications & incidents	Counts grouped by status; backend policy_health.	Implemented; individual distributions unverified. UI “in flight” currently includes resolved incidents.
Feedback helpfulness	True ratings / all feedback rows; null for zero feedback.	Implemented, metric-specific tests needed. Duplicate ratings can skew result; null must not appear as 0% satisfaction.
Citation activity	Top five policies by citation-row count, not unique people or sessions.	Implemented, ranking edge cases unverified.
Control test pass status	C-01 15/15, C-02 26/26, C-03 55/55 in November 5 test profiles.	Tested technical evidence only; no production or legal-compliance percentage.
Pulse source freshness	Per-source ok, count, stale, error, checked_at; 30-minute request-driven cache.	Tested offline; live refresh on November 5 blocked by proxy 403. No uptime SLA demonstrated.

Monitoring cadence and escalation - proposed

Weekly: technical owner reviews failing regressions, open defects and control evidence. Monthly: Compliance Lead issues status report and reviews policy/incident workload. Quarterly: Product Owner reviews residual risks, access review and policy-review timeliness. Immediately: critical exposure or authentication failure escalates to designated owner. Each review creates a dated record with action owner and closure evidence.

Do not report unsupported KPIs

No verified training completion, SLA attainment, incident mean-time-to-resolution, acknowledgment coverage, comprehensive regulatory coverage or audit-completeness score is available. Such measures should be added only after events, timestamps and denominator rules are implemented and tested.

04 Records management & retention SOP

Scope: controlled policies, approvals, incident/clarification records, security/audit evidence, regulatory review decisions, and management reports. The following is a proposed procedure—not evidence of a deployed retention engine.

RECORD CLASS	CUSTODIAN	RETENTION TRIGGER / RULE
Approved policies and prior versions	Compliance Lead / Policy Owner	Version supersession or policy retirement; duration subject to legal and client schedule approval.
Security tests and audit findings	Security / Compliance Lead	Audit closeout and remediation verification; duration to be approved.
Incidents and clarifications	Application Admin / Compliance Lead	Case closure; duration and privacy restrictions to be approved.
Management reports and sign-offs	Compliance Lead	Report approval/distribution date; duration to be approved.
Regulatory decisions	Compliance Lead / Policy Owner	Decision or policy-change approval date; persistence not yet implemented.

Required operational steps

1. Classify. Assign record ID, sensitivity, owner and applicable retention schedule. 2. Restrict. Apply least-privilege access and record authorized disclosure. 3. Preserve. Maintain version and evidence integrity with controlled backups and a traceable evidence register. 4. Hold. Suspend normal disposal during a documented investigation or legal hold. 5. Dispose. Require authorized review, legal-hold check and documented destruction/disposition. 6. Verify. Periodically test access, restoration, retention and disposal controls.

No invented retention duration: The source inventory does not establish applicable contractual, jurisdictional, regulatory or client-specific periods. Legal/Compliance must approve a retention schedule before automated purge rules or fixed years are declared.

Access and evidentiary safeguards

Audit datasets may contain employee-related case information. Limit report distribution; sanitize credentials, personal data and message bodies. Store evidence with date, origin, test/environment, checksum when available, reviewer and restricted access. Git hashes alone do not verify immutable production records or backup recovery.

05 Evidence index and corrective-action register

EVIDENCE / REGISTER ID	BASIS	CONCLUSION
EV-01: Security baseline (Nov 3)	docs/compliance/rubric1_security_test_results.md	C-01 0/15, C-02 16/26 at baseline.
EV-02: C-03 source audit (Nov 3)	docs/compliance/assignment3_c03_audit_results.md	54/55; source-host attribution failure documented.
EV-03: Verified retest (Nov 5)	docs/compliance/assignment3_security_hardening_final.md; dated verification_results.json	C-01 15/15; C-02 26/26; C-03 55/55 in controlled test profiles.
EV-04: Browser verification (Nov 5)	docs/compliance/evidence/browser_resume_2026-11-05_EF61bG/browser_results.json	14 passed, one blocked (Messages); no runtime exceptions reported.
EV-05: Assignment 4 inventory	assignment4_gap_analysis.md, commit c4641b5	Source/code review; no new tests, live data review or implementation.

ACTION ID / PRIORITY	OWNER	CLOSURE CRITERION
R-01 / P0 Secure normal launch	Technical Lead	Guard or retire unprotected main:app; demonstrate only authenticated secured profile is deployed.
R-02 / P1 Reporting accuracy	Compliance + Technical	Verify review cutoff, resolved incidents, zero/duplicate feedback, citation ordering and UI graph scales.
R-03 / P1 Approval and evidence history	Product / Technical	Approval events and report sign-off recorded and tested; evidence register has owner/date/reviewer.
R-04 / P1 Records controls	Compliance / Legal	Approved retention schedule and legal hold, access review and disposal process documented/tested.
R-05 / P1 Case workflows	Application Lead	GET /messages and incident guidance behavior pass end-to-end browser/API tests.
R-06 / P1 Deployment validation	Technical Lead	Supabase Auth mapping, staging database controls, and external feed access validated in approved environment.

Status & source basis

Draft for course submission. No management sign-off, retention schedule, controlled distribution, live Supabase verification or production certification is claimed. Based on the November 5 Codex gap analysis (commit c4641b5) and the November 3–5 security audit evidence.